

Seminar Report on Express: Lowering the Cost of Metadata-hiding Communication with Cryptographic Privacy

Carina Fehr (*remember to remove ID for the first draft and peer review!*)

October 9, 2025

Abstract

This report studies the reproducibility and performance of Express, a system for metadata-hiding communication. Using two servers, express ensures cryptographic security against at most one malicious server and an arbitrary number of malicious clients. The paper presents new protocols that offer low communication overhead, regardless of the number of users, and improved computation costs using symmetric key cryptography. Compared to Pung and Riposte, two previous cryptographically secure systems, Express achieves increased message throughput, while maintaining strong privacy guarantees. This makes Express an ideal applications for communication between whistleblowers and journalists.

1 Introduction

In today's digital landscape, secure communication has become increasingly crucial, with growing capabilities of surveillance and metadata analysis. Secure messaging apps like Signal and Transport Layer Security (TLS) encrypt the content of sent messages, but they do not protect metadata. It is possible to observe who sent and received messages, when and how often they communicated and how much data they exchanged. These information are as sensitive as the message itself and should therefore not be leaked. It is challenging to keep all metadata hidden, as most services for communication over the internet rely on some of them. An option for metadata hiding would be using a TOR browser or SecureDrop, but they are vulnerable to attacks by adversaries that control many network points. Other existing systems to hide metadata either have a high communication cost to be used in reality, or they have low computation cost but their security gets worse with every round of communication, also making them impractical.

While two servers are required, express still runs with one malicious server (Eskandarian et al., 2021). Express' target audience are journalists and whistleblowers. To receive messages, a journalist, also called client in the client-server architecture, registers a mailbox with the two servers. The server assigns a 128-bit virtual address to each mailbox and maintains a page table in which it stores the corresponding physical address. The journalist can transmit this address to the whistleblower. Now the client can upload a message into the mailbox. No one except the mailbox owner will know that a message has been sent into this mailbox. Mailbox owners have to check their mailboxes regularly. Express does not hide when a client read from a mailbox, therefore a pattern in the interval of checking could reveal something about activity of this mailbox. Additionally, Express must implement a possibility for cover traffic. This provides whistleblowers with plausible deniability and ensures that they cannot be accused of giving information simply for contacting an Express Server.

There are different types of attacks that Express must be resilient against. All clients can read from all mailboxes, so Express must re-encrypt the mailboxes differently each time a read happens, providing a decryption only the owner can decrypt. All others can neither read the content nor learn anything about which client is writing, even when reading the content of all mailboxes between every pair of writes. Another possible threat would be a malicious client targeting all mailboxes. It could overwrite all mailboxes with one message. Because the mailboxes can only hold a maximum of one message, all messages sent before this will be lost due to this denial-of-server attack. The complete overview is divided between the two servers, which means that the servers alone cannot recognise that this is not a valid message. A new auditing protocol presented in the paper is used to prevent such attacks. However, a malicious client could also attack just one mailbox, in which case the message would be completely correct and the server would

have no way of detecting and preventing the attack. Virtual addresses are used to prevent the original messages in the mailbox from being overwritten. The address range is so large that the probability of hitting a specific mailbox is negligible.

2 Background

This section explain two key concepts that form the foundation of Express: cryptographic privacy and distributed point functions, also called DPFS. In the following section, we will show how they can be used to achieve efficient metadata-hiding communication.

2.1 Cryptographic privacy

Cryptographic privacy is a mechanism that guarantees no information about communication metadata leaks to an adversary. Even after observing many rounds of communication, the adversary cannot determine which clients are communicating with each other or which mailbox a message was written to.

An alternative mechanism is differential privacy. After several rounds of communication, systems based on differential privacy such as Vuvuzela or Stadium, will lose security. Consistent observation will lead to some leaked information. Therefore, although cryptographic privacy is slower, it is the preferred approach for a frequently used applications.

2.2 Distributed point function

A DPF (<https://eprint.iacr.org/2023/028.pdf>) is a cryptographic algorithm. It splits a function f into function shares that individually hide f . The point function $f_{a,b}(x)$ outputs b at the point $x = a$ and 0 everywhere else. The two or more parts of the function individually reveal nothing about the function.

Express splits the function into two parts, one for each of the servers. Because no server alone can reconstruct the full function, even a malicious or compromised server cannot tell anything about the function and learns nothing about which mailbox a client wrote into.

3 Private Communication in Express

In this section, we will explain how an Express client writes messages into mailboxes and how the servers store them.

3.1 Express Servers

Secret sharing with DPFs. If the express servers hold n mailboxes together and each of them contains an element of the finite field $\mathbb{F}$, the totality of all mailboxes can be represented as a vector: $D \in \mathbb{F}^n$. D can therefore be represented as the sum of the two components $D_A + D_B = D$, where the vector belonging to server A corresponds to $D_A \in \mathbb{F}^n$ and server B's vector corresponds to $D_B \in \mathbb{F}^n$. When the servers receive a new message w , they can both add this vector to their current status: $D_A \leftarrow D_A + w_A \in \mathbb{F}^n$ and equally $D_B \leftarrow D_B + w_B \in \mathbb{F}^n$.

By using DPFs, as explained in the following subchapter, the servers do not receive a complete vector, but only a function share. They can evaluate this at any point, i.e. for each mailbox. This gives them the vectors, which they can add to D_A and D_B as before.

Distribution of trust. To prevent one server from containing all the data, thus representing a single point of failure and not providing adequate security for metadata hiding, multiple servers must be used. One way to achieve this distribution of trust would be to use a large number of servers. This offers the advantage that even if more than one server is malicious, the system can still continue to run.

Express uses only two servers, which in the paper are the Wall Street Journal and the Washington Post. These two must therefore meet stricter security requirements. One difficulty in implementing Express could be censorship. If access to one of the two servers is blocked, the entire application will no longer function. Express is less suitable for countries where news websites, i.e. servers on which Express runs, are often restricted.

Malicious server Another danger is posed by a malicious server. A denial of service attack can originate

not only from a client, but also from a server. The server can overwrite the contents of all mailboxes with meaningless content, causing the original content to be lost. However, since the client will realise that the contents of their mailbox are garbage, they can recognise that the system can no longer be trusted.

3.2 Express Clients

If a client wants to write a message $m \in \mathbb{F}$ to a mailbox, it can insert it into a vector of the length of all mailboxes by multiplying it with the i -th standard-basis vector $\mathbf{e}_i$. This vector should be zero everywhere except at the location of the targeted mailbox. Mathematically, this can be formulated as follows: $m \cdot \mathbf{e}_i \in \mathbb{F}^n$. This vector must then be split so that one can be sent to each server; i.e. $w_A + w_B = m \cdot \mathbf{e}_i$. However, the costs of these calculations are high. For every message that the client sends, it must have an element in the vector for each mailbox in the system and send it to both servers. A better alternative is to use DPFs, which allows clients to send less data. As explained in section 2.2, it is possible to split a function into two parts that, on their own, do not reveal anything about the function. We call the functions for the two Servers A and B f_A and f_B . When added together, they give exactly the value of f at each point. This point function can therefore also be written as follows: $f_{i^*,m} : [N] \rightarrow \mathbb{F}$. i^* is the only point at which this function does not yield zero, but rather m . Clients can now generate the shares f_A and f_B . Added at any point $i \in [N]$ they result in the DPF: $f_A(i) + f_B(i) = f_{i^*,m}$. Individually, these do not tell an attacker anything about i^* , i.e. the mailbox being written to, or about m , i.e. the message being transmitted.

The use of DPFs has reduced the size of sent messages to such an extent that, with a security parameter λ , each part of the function now has a length of $O(\lambda \log N + |m|)$ bits.

The messages sent by clients should either all be the same size or consist of a predefined set of sizes. If an attacker can extract information from the message size, the system loses security and the cover traffic no longer provides sufficient plausible deniability.

4 Protecting Privacy and Integrity

In this section we first show how Express ensures privacy when all clients behave legitimately, and then when at least one is malicious. At the end, we will show how Express can be used as a tool for communication between whistleblowers and journalists.

4.1 Privacy with honest clients

The previous chapter (3) explained how we can write something secretly to the server. However, an adversary could now check all network traffic. If they compare the contents of all mailboxes after each write, they will not be able to read the message because it is encrypted, but they can find out which client wrote to which mailbox.

To ensure that the metadata is completely hidden, we also need to control who reads the mailboxes. This could be prevented by only allowing reading once all clients have written, i.e. by running the system in batches. Pung and Riposte are based on this concept. However, this severely limits actual usability. Express has therefore proposed a method that does not require synchronised rounds. To achieve this, we must ensure that an attacker cannot view the messages or identify which mailbox has been modified after a message has been sent. The only person entitled to this information is the owner of the mailbox.

Express uses a lightweight cryptographic algorithm based on symmetric cryptography. Before changing the contents of a mailbox, the servers must decrypt it and then re-encrypt it. To do this, both servers receive their keys k_A and k_B from the client when creating a mailbox. After each change, all mailboxes are re-encrypted. This means that an attacker cannot find out which mailbox a message has been stored in unless they have both keys.

A counter is used for encryption. So when re-encryption is required, the previous value is subtracted and the new value added, which is a commutative operation. It is not necessary to re-encrypt after every write, but only if a read has occurred between writes. Otherwise, no one, including an attacker, has obtained any information. This increases the efficiency of encryption. In addition, it is not absolutely necessary for both servers to perform the re-encryption. If one of the servers has been corrupted and no longer re-encrypts, the system remains secure.

4.2 Privacy with malicious clients

The techniques presented in the previous chapter only provide security as long as all clients behave honestly. Even a single malicious client can attack and damage both servers. Nothing prevents a client from creating a vector that writes to multiple mailboxes simultaneously. To do this, it creates a DPF whose added vectors w_A and w_B , calculated from the functions f_A and f_B , are not zero everywhere or in multiple indices. Thus, one message from a malicious client is sufficient to overwrite all mailboxes and thereby delete the original content. Express has introduced an auditing protocol to prevent this. This ensures that each write only updated only one mailbox. Each vector to be inserted must therefore have a zero as an element at every position except one. If the vector does not meet this requirement, it can be discarded, meaning that the write request is rejected by the server and nothing is written to any mailbox.

4.3 Express for Whistleblowing

As explained in the previous chapters, Express offers a secure communication option. Outside of the data transfer itself, there are two more safety issues that should be considered. First, we need plausible deniability, second, we need a way to agree on a Mailbox address.

4.3.1 plausible deniability / cover traffic

If whistleblowers were the only users of Express, it would be obvious that anyone who sent a message over Express had passed on information. This means that many users that are not involved in whistleblowing must also send messages, creating cover traffic. To achieve this, a JavaScript program can be integrated into a website with high traffic, such as a news site. Every time a user visits this website, a dummy request is sent to the Express servers. The servers generate a key that is not known to any client. This means that these messages cannot be read, but they also cannot be distinguished from those of the whistleblowers.

News websites like New York Times benefit from high cover traffic because whistleblowers feel safer and are more likely to pass on information. This makes such sites particularly suitable for integrating JavaScript. The paper(!!) does not specify how cover traffic is required exactly, but it should be enough to ensure that real messages remain indistinguishable from the generated ones. The cost and computation times are very low, which can further encourage the use of Express.

4.3.2 Dialing

To select the mailbox address, the journalist and the whistleblower can meet in person. However, this is often not possible. In this case, a dialling protocol can be used. For example, the Riposte system could be used as a basis and made faster and cheaper with the improvements identified in Express. Journalists post their public keys for Riposte online, then whistleblowers can send them a mailbox address. The Journalist can download their messages and register the mailboxes.

5 Related work

In this section we will present Pung and Riposte, two previous metadata-hiding communication systems working with the concept of mailboxes. Then we will compare their security and performance to Express.

5.1 Pung

Pung (Angel and Setty, 2016) is designed to provide privacy guarantees of both message content and metadata. Its focus lies on protection against powerful global adversaries who may control the entire network infrastructure. This could be mass surveillance or state-sponsored attacks. In Pung, clients deposit and retrieve messages through an untrusted key-value stores. Only one untrusted server is required. Pung's main goal is to hide the communication patterns of clients who already know each other's identities. It allows two or more users to exchange messages over a public network without anyone else learning that they communicated. While reducing the costs compared to prior approaches, Pung's network costs still remain high. Pung provides privacy even when the server is malicious.

Pung was able to significantly reduce the calculation costs compared to previous work, but the network costs are high. It is particularly suitable when a client reads several messages at once.

5.2 Riposte

Riposte protects against network surveillance and malicious clients (Corrigan-Gibbs et al., 2015). Like Express, the main target group is whistleblowers who want to leak information anonymously. Riposte users can post messages anonymously on a bulletin board, it therefore functions as a broadcast service. Using DPFs and a private information retrieval (PIR), Riposte minimizes the number of bits each client must upload to each server.

5.3 Comparison

All three application focus on combining scalability with a guarantee of high privacy. A significant disadvantage of Pung and Riposte compared to Express is that with both, each client must have written their message before anyone can read it.

For a fixed security parameter λ , Express' auditing protocol requires $O(\lambda)$ communication between parties and $O(1)$ client side communication. Riposte on the other hand required $\Omega(\lambda\sqrt{n})$ communication and $\Omega(\sqrt{n})$ client computation. In addition, Riposte requires three servers instead of two like Express. This results in the new auditing scheme reducing the costs for the client by $8\times$ for an installation with one million registered mailboxes.

Significant events prior to the research of Express have led to Express testing significantly larger messages than previous systems. In 2019, a whistleblower submitted a report about President Trump and his interactions with the leader of Ukraine (anonymous, 2019). The file had a size of 25.3 KB and showed how important it is to offer whistleblowers the option of sending long messages.

Overall Express reduces the costs of maintaining a service for whistleblowers by $6\times$ compared to previous work with the same objective.

6 Conclusion

7 Use of generative digital tools

The use of AI tools must always be declared completely and transparently. For examples of how to do this, please see the DMI guidance: https://dmi.unibas.ch/fileadmin/user_upload/dmi/Studium/Computer_Science/Diverses/Wegleitungen/Dokumente_2023/Guidance_on_AI_in_teaching_in_Computer_Science.pdf.

References

- Angel, S. and Setty, S. (2016). Unobservable communication over fully untrusted infrastructure. In *12th USENIX Symposium on Operating Systems Design and Implementation (OSDI 16)*, pages 551–569, Savannah, GA. USENIX Association.
- anonymous (2019). Whistleblower Complaint | DocumentCloud — [embed.documentcloud.org](https://embed.documentcloud.org/documents/6430351-Whistleblower-Complaint/?mode=document&embed=1). <https://embed.documentcloud.org/documents/6430351-Whistleblower-Complaint/?mode=document&embed=1>. [Accessed 09-10-2025].
- Corrigan-Gibbs, H., Boneh, D., and Mazières, D. (2015). Riposte: An anonymous messaging system handling millions of users. In *2015 IEEE Symposium on Security and Privacy*, page 321–338. IEEE.
- Eskandarian, S., Corrigan-Gibbs, H., Zaharia, M., and Boneh, D. (2021). Express: Lowering the cost of metadata-hiding communication with cryptographic privacy. In *30th USENIX Security Symposium (USENIX Security 21)*, pages 1775–1792. USENIX Association.



University
of Basel

Faculty of Science



Declaration on Scientific Integrity

(including a Declaration on Plagiarism and Fraud)

Translation from German original

Title of Thesis: _____

Name Assessor: _____

Name Student: _____

Matriculation No.: _____

I attest with my signature that I have written this work independently and without outside help. I also attest that the information concerning the sources used in this work is true and complete in every respect. All sources that have been quoted or paraphrased have been marked accordingly.

Additionally, I affirm that any text passages written with the help of AI-supported technology are marked as such, including a reference to the AI-supported program used. This paper may be checked for plagiarism and use of AI-supported technology using the appropriate software. I understand that unethical conduct may lead to a grade of 1 or "fail" or expulsion from the study program.

Place, Date: _____ Student: _____

Will this work, or parts of it, be published?

No

Yes. With my signature I confirm that I agree to a publication of the work (print/digital) in the library, on the research database of the University of Basel and/or on the document server of the department. Likewise, I agree to the bibliographic reference in the catalog SLSP (Swiss Library Service Platform). (cross out as applicable)

Publication as of: _____

Place, Date: _____ Student: _____

Place, Date: _____ Assessor: _____

Please enclose a completed and signed copy of this declaration in your Bachelor's or Master's thesis.

September 2023